

SINGLE BUYER / LSS REPOSITORY

User management implementation guide

Microsoft Entra ID + Blazor .NET 10 + SQL Server

A practical guide to establishing the first administrator, approving staff, revoking access and maintaining an auditable user registry.

IMPORTANT / THE ACCESS RULE

Microsoft authenticates the person. LSS reads the person's approval status and role from SQL Server before granting repository access.

Document	Details
Version / date	1.0 / 14 September 2026
Audience	LSS administrators, developers and IT/database operators
Implementation	LSS-Entra-Login-Test; server-side Blazor; SQL Express
Current state	SQL schema and first-admin bootstrap completed locally. Integration and six automated tests passed. Real Entra acceptance testing remains a team task.

Reading route

- 02 Architecture and access rules
- 03 Environment and Entra setup
- 04 Database and first administrator
- 05 Daily administration
- 06 Developer implementation
- 07 Verification and troubleshooting
- 08 Operational handover and references

Scope: the implemented user-management module. Email, plant APIs, report generation and scheduling are separate workstreams. No credentials or secret values are included.

How access works

LSS uses Microsoft.Identity.Web and Microsoft.Identity.Web.UI for OpenID Connect sign-in and a server-managed authentication cookie. LSS maintains application access decisions in SQL Server.

Stage	What happens
1 / Microsoft sign-in	The user selects Sign in with Microsoft. Entra authenticates the account under the tenant's sign-in policies.
2 / Identity match	LSS uses the validated tenant ID (tid) and user Object ID (oid). An unknown identity in the configured tenant is registered as Pending / None.
3 / SQL decision	Authorization checks read the current registry. Approved Admin and Staff may enter repository pages. Pending and Revoked users are blocked.
4 / Administration	The sole LSS Admin approves or revokes staff. Access changes and their audit records commit together.

Roles and landing pages

SQL status / role	Landing	Allowed access
Approved / Admin	/admin	Repository, user registry and admin features
Approved / Staff	/protected	Repository; no user administration
Pending / None	/pending	Approval status and sign-out
Revoked / retained role	/revoked	Revocation status and sign-out

Revocation preserves the user record and may retain its previous role for history. Only Approved status allows that role to grant repository access.

Why email does not establish Admin

Email and preferred_username can change. The first administrator is bound to the operator-verified tenant/user Object ID pair. A matching email alone never grants Admin. Microsoft documents stable object identifiers and warns against email-based authorization [1].

The LSS Admin role is separate from Microsoft Entra administrative roles. LSS approval does not grant Microsoft 365 or tenant administration privileges.

IMPORTANT / ONE APPROVED ADMIN

The SQL unique index prevents two approved Admins. The app prevents revoking the current Admin and supports an atomic transfer to approved Staff. InitialAdminUserId records history, not permanent entitlement.

Prepare the environment

For a fresh installation, complete these steps before first use. For the current local installation, verify existing settings and continue to daily administration.

1. Confirm prerequisites

Install the .NET 10 SDK, SQL Server/SQL Express and SSMS. Confirm the SQL service is running and the app-running Windows identity has database access.

Local setting	Value
SQL instance / database	localhost\SQLEXPRESS / LSSRepo
App URL	https://localhost:7020
HTTP listener	http://localhost:5245 (redirects to HTTPS)
Connection file	database-settings.json
Connection override	ConnectionStrings:LssDatabase or environment variable ConnectionStrings__LssDatabase

2. Prepare the Entra registration

Use an organisational, single-tenant Web app registration. Obtain the Directory (tenant) ID and Application (client) ID [2]. Configure the following local URLs.

Purpose	URL
Web sign-in redirect	https://localhost:7020/signin-oidc
Web sign-out callback	https://localhost:7020/signout-callback-oidc
Front-channel logout	https://localhost:7020/signout-oidc

The app uses authorization code flow; leave implicit token grants disabled. Preserve the existing authentication routes and Microsoft sign-out behaviour.

3. Supply credentials securely

Configure AzureAd:TenantId, AzureAd:ClientId and AzureAd:ClientSecret through development User Secrets or your deployment credential mechanism. Do not commit secret values. Restart after changes.

4. Check the SQL connection

The local connection uses Windows authentication; no SQL password is stored. An external connection value overrides the local default.

```
Server=localhost\SQLEXPRESS;Database=LSSRepo;  
Integrated Security=True;Encrypt=True;  
TrustServerCertificate=True;Connect Timeout=10
```

TrustServerCertificate=True is for local development. Deployment should use a trusted SQL certificate and restricted service identity. Graph Mail.Send consent is not required for LSS role approval.

Create the first administrator

IMPORTANT / ALREADY COMPLETED LOCALLY

LSSRepo already contains the schema and an Approved / Admin account. Do not rerun 001 or 002. These steps document provisioning for a fresh environment.

1. Create the schema once

In SSMS, connect to localhost\SQLEXPRESS and select the existing LSSRepo database. Review and execute database/001_create_access_schema.sql in full. It creates five lss tables and their constraints in a transaction.

2. Verify the nominated Microsoft identity

Verify the organisation Tenant ID and nominated user's Object ID in Entra. Copy the user Object ID from the user record, not the client ID or app-registration Object ID.

Local provisioned identity	Operator-supplied value
Name / account	Suaid Ishak / suaid.ishak@sae-malaysia.com
Tenant ID	27971c0d-2474-4fa6-bc9c-d30415822fc9
User Object ID	0ff6f36b-a708-4653-b78a-c926f0785a49

3. Run bootstrap once on an empty installation

Open database/002_bootstrap_admin.sql. Put verified identifiers in the DECLARE assignments at the top; leave the NULL/zero-GUID guard intact. The current file is already populated for the local identity above.

Bootstrap locks setup, refuses an existing installation, creates the Admin, writes a Bootstrapped audit entry and marks SystemSetup complete. All changes commit together. The script itself does not verify the identity against Entra.

4. Verify with read-only SQL

Expect BootstrapCompleted = 1, a populated InitialAdminUserId and exactly one Approved / Admin user.

```
USE [LSSRepo];
SELECT SetupId, BootstrapCompleted, InitialAdminUserId
FROM lss.SystemSetup;
```

```
SELECT UserId, DisplayName, StatusCode, RoleCode
FROM lss.Users;
```

```
SELECT COUNT(*) AS ApprovedAdminCount
FROM lss.Users
WHERE StatusCode = 'Approved' AND RoleCode = 'Admin';
```

If setup/users already exist, inspect the current state. Do not delete records or alter guards to force bootstrap. A lost administrator requires a reviewed operator recovery process.

Daily administrator workflow

1. Start and sign in

Open <https://localhost:7020> and sign in with the provisioned account. An approved Admin is routed to /admin. The list shows status, role, latest sign-in and activity.

```
dotnet run --project Lss.EntraLoginTest.csproj --launch-profile https
```

2. Let a new user sign in

The user signs in with an account admitted by the configured tenant. LSS creates Pending / None and displays pending approval. Repository and admin pages remain blocked.

3. Approve Staff

Refresh the admin list. Verify the person and business need. Choose Approve / restore Staff and Save for that row. The user selects Check approval status or navigates to /access.

4. Revoke or restore

Choose Revoke access and Save. Future protected requests/actions are denied; the record stays in the registry. Re-login does not restore access. Choose Approve / restore Staff to restore it.

5. Transfer administration when required

First approve the successor as Staff. Expand Transfer administration, read the consequence, tick confirmation and select Transfer to this user. The successor becomes the sole Admin; the previous Admin becomes Staff.

IMPORTANT / BEFORE CONFIRMING A TRANSFER

Verify the successor can sign in and is ready to take responsibility. Afterwards, the previous Admin cannot manage users. Bootstrap history does not automatically restore authority.

Reading the registry

The list includes provisioned accounts and users who accessed LSS, not every Entra directory user. A provisioned account may show Not yet until its first sign-in. Refresh to see new users.

Times are UTC. Recently active means recorded activity within 15 minutes, not an exact live-session count. Closing a tab or signing out does not remove the user.

If an update is rejected

Refresh if access changed after you loaded the page. Review the latest status before retrying. An invalid form token also requires a reload. Staff cannot change roles by posting directly to the administrative endpoint.

Restarting the app

In the terminal running the app, press Ctrl+C, then run the command above again. If started through an IDE debugger, stop that debug session first. Database roles persist across restarts.

Implementation and database design

Component	Responsibility
Program.cs	Registers Microsoft authentication and policies; records activity; routes by status; validates antiforgery on administrative POSTs.
Access/UserRegistry.cs	Uses validated tid/oid; registers Pending users; reads roles; updates access and audit transactionally.
RegistryAuthorization.cs	Default policy requires approved Staff or Admin; Admin policy requires approved Admin.
RegistryRevalidation.cs	Rechecks interactive server authentication every 30 seconds; fails closed on registry validation failure.
Components/Pages/Admin.razor	Lists users and provides approve/revoke and confirmed transfer forms.

Five SQL tables

Table	Purpose and rules
Iss.Roles / Iss.AccessStatuses	Lookup keys: None, Staff, Admin; Pending, Approved, Revoked.
Iss.SystemSetup	Singleton installation/tenant; schema version, completed bootstrap and original admin reference.
Iss.Users	Identity primary key; unique tenant/object pair; tenant and lookup foreign keys; valid status/role combinations; AuthorizationVersion and RowVersion.
Iss.AccessAudit	Target/actor references; previous/new status and role; action, reason, UTC time and correlation ID. No cascading deletes.

Transactions and concurrency

Changes acquire the LSS.AccessAdministration transaction lock and recheck the actor. Submitted AuthorizationVersion detects a stale form. The SQL update also matches RowVersion, increments the authorization version and inserts an audit entry atomically. Rowversion is a concurrency value, not a timestamp [4].

A transfer demotes the old Admin, promotes the successor, verifies one approved Admin remains and records both changes under one correlation ID. Failure rolls back the transaction.

Protecting new features

Use [Authorize] on repository pages and [Authorize(Policy = "Admin")] on admin pages. Interactive handlers and data services must also check the current registry before protected work. Hiding a menu is insufficient [3].

Verification and troubleshooting

Use separate browser profiles for Admin and a new user. Record the tester, date and result of each scenario.

Test	Expected result
Admin signs in	/admin opens; Approved / Admin shown.
New user signs in	Pending / None created; /pending opens.
Pending user opens protected URLs	/protected and /admin denied.
Approve Staff	/protected allowed; /admin still denied.
Revoke and re-login	Protected requests/actions denied; Revoked persists.
Restore Staff	Repository allowed; administration still denied.
Transfer to approved Staff	Successor Admin; former Admin Staff; exactly one Admin.
Restart and sign out	Roles persist; existing Microsoft logout still works.

Automated evidence

```
dotnet build Lss.EntraLoginTest.slnx
dotnet test tests/AccessTests/AccessTests.csproj
```

On 14 September 2026, the implementation build passed with zero warnings/errors and all six tests passed. SQL workflows and existing email regressions were checked. Tests create/drop isolated LssAccessTests_* databases with synthetic identities; they do not mutate LSSRepo or send email. The HTTPS login page was browser-checked. Real Entra/MFA acceptance testing remains manual.

Symptom	Action
AADSTS50011	Start at https://localhost:7020. Match the Web callback, including HTTPS. Initiate a fresh sign-in.
SQL / startup failure	Check service, target database, Windows permissions, schema/bootstrap and tenant match. No JSON fallback exists.
Expected Admin is Pending	Compare validated tenant/user Object IDs with SQL. Do not grant by email or rerun bootstrap.
Old page after revocation	Refresh. Protected actions recheck SQL; circuits also revalidate every 30 seconds. Already displayed data cannot be erased.

Team handover and references

Owner	Responsibility
LSS Admin	Confirm business need, approve/revoke users and coordinate administrator transfers.
Entra / IT operator	Manage registration, credentials and tenant sign-in policies; verify bootstrap/recovery identities.
Database operator	Maintain service access, backups and recovery; protect audit/setup data; handle exceptional audited recovery.
Application team	Protect new routes/actions, preserve transactional rules and run regression/acceptance checks.

Before a shared deployment

Use a restricted runtime service identity, not `dbo/db_owner`. Limit audit permissions to `SELECT/INSERT` and setup/lookups to `SELECT`. Establish backups, restore testing and a named operator recovery owner. Application-generated audit entries are not tamper-proof against privileged database administrators.

Startup verifies completed bootstrap, schema version, tenant match and one approved Admin. SQL availability is required for authorization. The old `App_Data/users.json` remains unused; its roles are not automatically imported.

LSS revocation changes local access. It does not disable the Microsoft account or terminate every Microsoft 365 session. Coordinate Entra account lifecycle and LSS approval with IT.

Current boundaries

No directory-wide user sync, fine-grained page roles, automated offboarding sync or built-in emergency-admin recovery is implemented. Email and Graph Mail.Send consent are separate from LSS user approval.

Implementation sources

Based on `Program.cs`; `Access/UserRegistry.cs`, `RegistryAuthorization.cs` and `RegistryRevalidation.cs`; `Components/Pages/Admin.razor`; `database/001_create_access_schema.sql` and `002_bootstrap_admin.sql`; project READMEs and `tests/AccessTests`. Reviewed 14 September 2026.

Microsoft references

[1] ID token claims: stable identity and display-only fields

[2] Register an application in Microsoft Entra ID

[3] Blazor authentication and authorization (.NET 10)

[4] SQL Server rowversion: concurrency token

The 30-second revalidation interval is specific to this LSS implementation.

IMPORTANT / TEAM ACCEPTANCE

Complete page 7 with real corporate accounts, confirm the nominated Admin and recovery owner, and retain the results with the release record.